Ch. 21 – Prise de notes

Cybersécurité et environnement numérique sécurisé · tout le cours en prise de notes

Abréviations : ANSSI = Agence nationale de la sécurité des systèmes d'information · ANS = Agence du numérique en santé · CERT = centre de réponse aux incidents · CPS = carte de professionnel de santé · PGSSI-S = politique générale de sécurité des systèmes d'information de santé · CaRE = programme Cybersécurité accélération et Résilience des Établissements · DIC = disponibilité, intégrité, confidentialité · Cci = copie cachée · RPO = perte de données maximale admissible · RTO = durée maximale d'interruption admissible · PCA / PRA = plan de continuité / de reprise d'activité · VPN = réseau privé virtuel · IC = intervalle de confiance · → = donne · ≠ = différent de

Corrections CNED : e-santé 2020 → **Ma santé 2022** → **feuille de route 2023-2027** + **CaRE (déc. 2023)** · DMP **dans Mon espace santé (2022)** · CPS + lecteur → aussi **e-CPS** et **Pro Santé Connect** · « hautement sécurisé » : la sécurité dépend aussi des **pratiques** · cybersécurité peu traitée · **NIS 2** : transposition **pas adoptée** au 26/10/2026 (vérifié en ligne ; Légifrance) · ex. 21.79 : 72 h dès le **vol** par prudence.

1. Acteurs et vocabulaire (21.3.1)

- Compétences **C3.6** (cœur), C3.5, C3.1 ; arrêté **27/11/2024** ; socle numérique ≈ **10 h** ; CNED S7 p. 25-27, Hygiène S4 § 5.
- **DIC** : disponibilité, intégrité, confidentialité ; + **traçabilité**, authentification.
- Bien · **menace** · **vulnérabilité** · **risque** (vraisemblance × gravité) · incident · violation (art. 4).
- **ANSSI 7/7/2009** (décret 2009-834) ; guide d'hygiène **42 mesures (2017)** ; cybermalveillance.gouv.fr 2017 ; **17Cyber 17/12/2024** ; **CERT Santé** (ANS).
- RGPD **art. 32** sécurité, **33** notification ; **NIS 2** 2022/2555 (14/12/2022 ; 17/10/2024).
- **Identification / authentification / habilitation** ; CPS, **e-CPS**, Pro Santé Connect ; RPPS. **Prêter sa CPS = prêter sa signature.**
- PGSSI-S : **opposable** seulement si un texte le prévoit. **CaRE** déc. 2023, ≈ **750 M€**, **4 axes** ; Dax, Villefranche 2021, CHSF 2022.
- **323-1 : 3 ans, 100 000 €** ; 226-13 : 1 an, 15 000 € ; art. 83 : **20 M€ / 4 %**. Victime **et** sanctionnable.
- Adresse : lire le **nom de domaine** ; cadenas = chiffré, **pas honnête**.

2. Mots de passe, double authentification (21.3.2)

- **6 gestes** : mots de passe, double authentification, mises à jour, sauvegardes, vigilance, usages séparés.
- Force brute, dictionnaire. Combinaisons = **caractères puissance longueur** (10 puissance 10 essais/s).
- 10 minuscules **3 h 55** ; 11 → **4,2 j** ; 12 → **110 j** ; 4 mots 4,2 j ; **6 mots 700 000 ans**.
- **Allonger > compliquer**. CNIL **2022-100 (21/7/2022)** : **12** car. 4 types, **14** car. 3 types, **7 mots**.
- **Sais / possède / suis** ; question secrète **≠** 2e facteur ; **fatigue des notifications** : ne jamais valider.
- Gestionnaire : coffre chiffré, mot de passe maître + 2FA ; **504 €/an** = 36 €/pers.

3. Mises à jour, comptes, messagerie (21.3.2)

- **Fin de support** ; appareils oubliés (sondes, box, imprimante) ; 5 étapes ; priorité **système** > navigateur.
- **Moindre privilège** ; départ = désactiver le dernier jour ; revue **11/64 = 17,2 %** ; « **un compte = une personne** ».
- **MSSanté** ; **Cci** : 140 × 139 = **19 460** ; lien nominatif à expiration ; mot de passe **par un autre canal**.
- **Chiffrement** → gravité ↓ ; inintelligible → pas d'information des personnes (**art. 34**), registre quand même.
- Macros : jamais « activer le contenu » ; **antivirus ne suffit pas** ; se déconnecter.

4. Sauvegardes (21.3.2)

- **3-2-1** : 3 copies, 2 supports, 1 hors ligne ; **restauration testée**.
- Complète · **incrémentale** (depuis la dernière sauvegarde : toutes) · **différentielle** (depuis la complète : la dernière).
- 40 Go + 1,5 Go/j : **49 Go/sem.** vs 71,5 Go ; incrémentale mardi illisible → lundi soir.
- **RPO** (perte) / **RTO** (arrêt) fixés **avec les métiers** ; 160 → 40 fiches (− 75 %) ; 11 h 50 → 1 h 50.

- Test **5 étapes** (chronométrer) ; conservation **30 j**, infra distincte ; 49 × 5 × 2 = **490 Go**.

5. Menaces, réaction, sensibilisation (21.3.3-21.3.4)

- **4 menaces** : hameçonnage, rançongiciel, usurpation, ingénierie sociale ; + faux support.
- Rançongiciel **6 étapes** : entrée, installation, exploration, vol, chiffrement, chantage ; **double extorsion** ; 23 j > 15 j.
- SMS → **33700** ; code QR ; IA : **demande inhabituelle** ; voix imitée 8 400 €.
- Virement : pas le seul message, **rappeler au numéro connu**, **double validation**.
- Patients : rétractation **14 j** (L221-18) ; aider sans culpabiliser. Prestataire : **responsable reste** (art. 28).
- **LOPMI 2023-22** (L12-10-1) : **plainte 72 h** ; **deux 72 h** (CNIL, plainte). Samedi 8 h → mardi 8 h.
- **Réagir** : isoler **sans éteindre**, alerter, préserver, signaler, restaurer, leçons. **Main courante papier.**
- Week-end compris : vendredi 18 h 50 → lundi 18 h 50 ; 30/12/2026 22 h → 2/1/2027 22 h ; EHPAD mercredi 11 h → **samedi 11 h**.
- **PCA ≠ PRA** ; liste de secours = risque ; un porte-parole ; **ne pas payer** ; RETEX **sans coupable**.
- Plan **6 étapes** ; simulé : DPO, non cruel, **aucun mot de passe enregistré**, anonyme.
- IC : **31,7 % [19,9 ; 43,4] → 11,7 % [3,5 ; 19,8]** ; 25 % [14 ; 36] : pas de conclusion ; 24 → 14,7 → 8 %.
- **3 signes** : urgence, argent ou données, promesse trop belle.

6. Inès, approfondissements, L3 (21.3.5-21.5)

- Inès : session perso, **verrouillage**, espace partagé sauvegardé, phrase de passe, faux mail CAF **signalé**, affiche.
- Capteur glycémie **288/j**, 105 120/an ; appli : Ciqual, données, hébergement ; **autorisation = fonction utilisée**.
- Distance : **VPN** ou partage de connexion ; téléphone : 6 chiffres, **effacement à distance** ; e-CPS changée.
- Téléconsultation : **lien unique + salle d'attente**, pas d'enregistrement.
- Libéral **3 temps** : semaine (gratuit), mois, année (**HDS**) ; **0,60 €**, 0,34 €, 0,24 € **vs 2 150 €**.
- **Cotation** V × G : 1-3 / 4-7 / 8-11 / 12-16 ; 23 → 7 (**− 69,6 %**) ; chiffrement = gravité, formation = vraisemblance.
- Fin de vie : effacement sûr, **attestation** ; **photocopieur** garde une copie.
- L3 : **EBIOS RM 2018, 5 ateliers** ; **culture juste** (erreur / risque / délibéré) ; RaaS ; 77,5 % priorité.

7. Cas, jury (21.6-21.8)

- Cas 1 : 303/820 = 37 % ; 620 €. Cas 6 : RTO **zéro** PAI. Cas 7 : **1 048 320** positions. Cas 8 : − 58,7 %.
- Cas 13 : 72 h dès l'appel. Cas 18 : 9,0 % ; la **commune** notifie. Cas 20 : 9,4 Go, une copie → 3-2-1.
- Oral : **situer, évaluer, protéger, réagir, justifier**. E5 : risque D/I/C, règle **datée**, mesure immédiate + durable, limites.
- Pièges : changer tous les mois, disque branché, **éteindre**, « pas notre problème », CNIL pour tout, sanctionner, « trop petite », NIS 2.
- QCM : 1 acd · 2 abd · 3 abc · 4 bc · 5 abc · 6 abd · 7 abd.